
ChurchGeniusPro

Access Controls Policy

Limiting access to production assets (physical and virtual) and sensitive data

Aligned to SOC 2 (CC6), ISO/IEC 27001 (A.5.15–5.18, A.8.2–8.5), NIST CSF 2.0 (PR.AA), and
OWASP

Version 1.0

Effective date: July 1, 2026

Next scheduled review: July 1, 2027 (or upon material change)

Owner: Security Lead / CISO

Classification: Internal

Purpose in brief. This policy defines who may access ChurchGeniusPro production systems and sensitive data, how that access is granted, restricted, reviewed, and revoked, and how it is enforced in the application and infrastructure. It is a companion to the Information Security Policy and the Data Deletion & Retention Policy. Controls described as “in place” reflect the current implementation; items marked “required” or “planned” are committed and tracked in the security risk register.

Contents

1. Purpose
 2. Scope
 3. Definitions
 4. Access Control Principles
 5. Roles and Responsibilities
 6. Role-Based Access Model
 7. Access Control Matrix
 8. Account Lifecycle (Joiner / Mover / Leaver)
 9. Authentication Requirements
 10. Authorization and Enforcement in the Application
 11. Production and Infrastructure Access
 12. Sensitive Data Access
 13. Privileged and Break-Glass Access
 14. Remote and Third-Party Access
 15. Physical Access
 16. Access Reviews and Recertification
 17. Logging and Monitoring of Access
 18. Enforcement, Exceptions and Review
- Appendix A — Control-to-Framework Mapping
- Appendix B — Joiner / Mover / Leaver Checklist

1. Purpose

Unauthorized or excessive access is a primary cause of data breaches. This policy limits access to ChurchGeniusPro production assets and sensitive data to authorized individuals, on a least-privilege and need-to-know basis, and ensures that access is granted deliberately, enforced technically, monitored, and revoked promptly when no longer required.

2. Scope

This policy applies to all human and non-human identities that can access the platform or its data:

- **Production assets (virtual):** the Spring Boot application, the PostgreSQL database, hosting/cloud console, CI/CD, secrets stores, log stores, and backups.
- **Production assets (physical):** data-center facilities (via the hosting provider) and any company endpoints used to administer production.
- **Sensitive data:** member/family PII, financial and donation records, children's-ministry data, credentials, and API secrets.
- **Identities:** end users (church members), church staff/administrators, ChurchGeniusPro personnel and contractors, service accounts, and sub-processors.

3. Definitions

Term	Meaning
Least privilege	Granting the minimum access needed to perform a role, and no more.
Need-to-know	Access to specific data only where the role requires it.
RBAC	Role-based access control — permissions attached to roles, roles assigned to users.
Tenant isolation	Restricting each church's data to that church, enforced by the client identifier (appId).
Privileged access	Administrative or elevated access to production systems or sensitive data.
Break-glass	Emergency, tightly-controlled access used only when normal paths are unavailable.
Deprovisioning	Full and timely removal of access when it is no longer required.

4. Access Control Principles

- **Deny by default.** Access is denied unless explicitly granted; the application gates protected endpoints and pages by default.
- **Least privilege and need-to-know.** Users receive only the access their role requires.
- **Segregation of duties.** Sensitive functions (e.g., financial administration vs. user administration) are separated where feasible.

- **Unique identity and accountability.** Every user has a unique account; shared accounts are prohibited; actions are attributable.
- **Defense in depth.** Authentication, authorization, tenant isolation, network restriction, and monitoring are layered.
- **Timely revocation.** Access is removed immediately on role change or departure.

5. Roles and Responsibilities

Party	Access-control responsibility
Security Lead / CISO	Owns this policy; approves privileged access and exceptions; oversees access reviews.
System / access owners	Approve access requests to the systems and data they own.
Operations / DevOps	Provision/deprovision infrastructure and production access; manage secrets and service accounts.
Engineering	Implement and maintain in-application access enforcement (filters, role/permission checks).
Church administrators	Manage their own church users and member access within their tenant.
All users	Protect their credentials; use only the access granted; report anomalies.

6. Role-Based Access Model

Access is governed by role, then refined by fine-grained permission keys and by tenant. The platform defines the following roles, enforced server-side:

Role	Typical access
SuperAdmin	Platform-level administration (ChurchGeniusPro personnel); highest privilege; strictly limited and monitored.
Admin	Church organization administrator; manages their church's configuration, users, and data.
Accountant	Financial/accounting functions (contributions, pledges, reports) within their church.
User	Staff user with task-specific, permission-gated access.
Church	Church-type login limited to its designated landing area.
Member	Congregation member; access restricted to the member portal and their own/family data.

Beyond role, page- and action-level **permission keys** (for example, `accounting.pledges`, `accounting.pledges.edit`, `accounting.pledges.delete`) grant granular capabilities, and all data access is scoped to the session's tenant (`appClientId`). Failed permission checks deny access rather than silently redirecting.

7. Access Control Matrix

The matrix summarizes baseline access. “Own” means limited to the user's own or family records; “Tenant” means limited to the user's church; “Full” means platform-wide (privileged).

Resource / data	Member	User	Accountant	Admin	SuperAdmin
Member portal (self/family)	Own	Tenant	Tenant	Tenant	Full
Member directory / profiles	—	Tenant*	Tenant	Tenant	Full
Contributions & pledges	Own	—*	Tenant	Tenant	Full
Financial reports	Own (tax)	—*	Tenant	Tenant	Full
Children's-ministry data	Own child	Tenant*	—	Tenant	Full
User / role administration	—	—	—	Tenant	Full
Church configuration	—	—	—	Tenant	Full
Production infra / database	—	—	—	—	Full**

* Subject to specific permission keys granted to the User role. ** Infrastructure/database access is limited to authorized operations personnel via privileged access (Section 11), not through application roles. The matrix is a baseline; the authoritative grant is the combination of role, permission keys, and tenant scope.

8. Account Lifecycle (Joiner / Mover / Leaver)

8.1 Joiner (provisioning)

- Access is requested with a business justification and approved by the system/data owner before it is granted.
- Accounts are created with least-privilege defaults; a unique identity is issued (no shared accounts).
- Privileged or production access requires additional CISO approval.

8.2 Mover (change of role)

- On role change, prior access is re-evaluated and reduced to what the new role requires (no privilege accumulation).
- Account status changes take effect immediately: the auth filter re-validates account enabled/disabled and deletion status on every request.

8.3 Leaver (deprovisioning)

- Access is revoked promptly on departure or contract end; accounts are disabled/deleted and sessions invalidated.
- Associated secrets, tokens, and service-account access the person held are rotated.
- Deprovisioning is tracked to completion (see Appendix B checklist).

9. Authentication Requirements

- Passwords are stored only as **BCrypt** hashes (work factor 10); plaintext storage is prohibited and any legacy plaintext row is migrated on next login.
- Password strength, lockout/throttling on repeated failures, and secure reset flows are required.
- Sessions are server-side (persisted to PostgreSQL); cookies are **HttpOnly** and **SameSite=Lax**, with the **Secure** flag enforced over HTTPS in production.
- Idle session timeout is 30 minutes; any “no auto-logout” option is risk-reviewed and should not apply to privileged sessions.
- **Multi-factor authentication is required for all privileged and production access** and is recommended for staff/administrator accounts (planned enhancement where not yet enforced).

10. Authorization and Enforcement in the Application

Access is enforced on the server by a layered servlet-filter chain and role/permission checks — never by the client alone:

- **Authentication gate:** protected API endpoints require a valid session; unauthenticated requests are rejected.
- **Continuous account validation:** the auth filter re-checks account enabled/deleted status on every request so revocation is immediate.
- **Role and permission checks:** server-side guards enforce role membership (SuperAdmin/Admin/Accountant/User/Church/Member) and fine-grained permission keys.
- **Tenant isolation:** every data query is scoped to the session's appId to prevent cross-church access.
- **Network-restricted pages:** designated sensitive areas can be limited to approved networks (“private page access”).
- **Constrained logins:** NFC-tag (NTAG) sessions are limited to an allow-list of pages; out-of-scope navigation is forwarded to access-denied.

11. Production and Infrastructure Access

- Direct access to production servers, the PostgreSQL database, cloud console, CI/CD, secrets, and backups is restricted to **named, authorized operations personnel** on least privilege.
- Production access requires MFA and is granted through controlled paths (e.g., bastion/jump host or provider IAM), not shared credentials.
- Application and database service accounts use scoped, least-privilege credentials supplied via environment variables or a secrets manager — never committed to source.
- Standing production access is minimized in favor of just-in-time, time-boxed grants where feasible.
- All production access is logged and reviewed; changes follow the change-management process.

12. Sensitive Data Access

- Access to **Restricted** data (children's-ministry data, financial/donation records, credentials, secrets) is granted strictly on need-to-know with the tightest controls.
- Children's-ministry records carry enhanced restrictions on who may view them and are never used outside their program purpose.
- Restricted data is not copied into non-production environments and is excluded from verbose logs.
- Bulk export and reporting of sensitive data is limited to authorized roles and logged.
- Data classification (Restricted / Confidential / Internal / Public) drives the access baseline per the Information Security Policy.

13. Privileged and Break-Glass Access

- Privileged (SuperAdmin/production) access is inventoried, individually approved by the CISO, MFA-protected, and reviewed at least quarterly.
- A **break-glass bypass token** exists for off-network administrator recovery. It must be stored as a secret, tightly restricted, rotated regularly, and its use alerted on and reviewed after every occurrence.
- **Temporary access** passes grant time-limited access that automatically expires and can be revoked; a filter enforces the window on every request.
- Privileged actions are logged with attribution; segregation of duties applies to the most sensitive operations.

14. Remote and Third-Party Access

- Remote administrative access uses encrypted channels and MFA; endpoints must meet endpoint-security requirements.
- Contractors receive least-privilege, time-boxed access under agreement, revoked at engagement end.
- Sub-processors (email, SMS/WhatsApp, OpenAI, push) receive only the minimum data and scoped API keys, bound by data-processing agreements and reviewed at least annually.
- Third-party API keys are rotated and revoked when a relationship ends.

15. Physical Access

- Production infrastructure is hosted in professional data centers whose physical security (access control, monitoring, environmental protection) is validated through the provider's attestations (e.g., SOC 2 / ISO 27001).
- Company offices and administrative endpoints that can reach production are physically secured; devices require disk encryption and auto-lock.
- Portable media use for sensitive data is discouraged and controlled; disposal follows secure media-sanitization requirements.

16. Access Reviews and Recertification

- User and role access is recertified at least **quarterly**; privileged/production access is reviewed at least quarterly and after any incident.
- Reviews confirm least privilege, remove unused or orphaned accounts, and validate segregation of duties.
- A monthly check confirms zero non-BCrypt (plaintext) password rows remain.
- Findings are remediated and tracked in the security risk register.

17. Logging and Monitoring of Access

- Authentication events, session attributes, and administrative actions are logged for traceability.
- Security-relevant events — authentication failures, privilege changes, break-glass token use, temporary-access grants — are monitored and alerted.
- Logs exclude secrets and restricted data and should be centralized in tamper-evident storage.
- Access logs are retained per the retention schedule and reviewed as part of access recertification.

18. Enforcement, Exceptions and Review

- Violations may result in access revocation, disciplinary action, and contractual remedies for third parties.
- Exceptions require documented CISO approval, a compensating control, and an expiry date.
- This policy is reviewed at least annually and after major changes or incidents; versions and approvals are recorded.

Appendix A — Control-to-Framework Mapping

Section	SOC 2 TSC	ISO 27001 (Annex A)	NIST CSF 2.0
Principles / least privilege (§4)	CC6.1	A.5.15, A.8.2	PR.AA-05
RBAC & matrix (§6–7)	CC6.1, CC6.3	A.5.15, A.8.3	PR.AA-05
Account lifecycle (§8)	CC6.2, CC6.3	A.5.16, A.5.18	PR.AA-01
Authentication (§9)	CC6.1	A.5.17, A.8.5	PR.AA-01/02/03
App enforcement (§10)	CC6.1, CC6.3	A.8.3, A.8.4	PR.AA-05
Production / infra access (§11)	CC6.1, CC6.6	A.8.2, A.8.4	PR.AA-05, PR.PS
Sensitive data access (§12)	CC6.1, C1.1	A.8.3, A.8.12	PR.DS, PR.AA
Privileged / break-glass (§13)	CC6.1	A.8.2	PR.AA-05
Third-party access (§14)	CC6.1, CC9.2	A.5.19–5.22	GV.SC, PR.AA
Physical access (§15)	CC6.4	A.7.1–7.4	PR.AA-06
Access reviews (§16)	CC6.2, CC6.3	A.5.18	PR.AA-05, GV
Logging / monitoring (§17)	CC6.1, CC7.2	A.8.15, A.8.16	DE.CM, DE.AE

Appendix B — Joiner / Mover / Leaver Checklist

Phase	Action	Owner
Joiner	Access request with justification approved by system/data owner	Manager / owner
	Create unique account with least-privilege role and permission keys	Ops / Admin
	Additional CISO approval + MFA enrollment for privileged/production access	CISO / Ops
Mover	Re-evaluate access for the new role; remove no-longer-needed rights	Manager / owner
	Confirm no privilege accumulation; update permission keys and tenant scope	Ops / Admin
Leaver	Disable/delete account and invalidate active sessions promptly	Ops / Admin
	Rotate secrets/tokens and revoke service-account and third-party access held	Ops
	Record completion; reflect in next access review	CISO

Note. This policy documents target-state access controls and the current implementation status of each. Items marked “required”, “planned”, or “recommended” (for example, MFA enforcement) are committed and tracked through the security risk register and quarterly access reviews.